

Alejandro Molina de Haro

25/02/2026

Activitat2 - RA3 - Parte2

Tabla de contenido

PARTE 5.....	2
1. Análisis del ataque Wi-Fi.....	2
2. Análisis del incidente del PDF	2
3. Riesgo del WPS y contraseña repetida	3
PARTE 6.....	4
PARTE 7 – Rediseño de la infraestructura	4
PARTE 8.....	5

PARTE 5

1. Análisis del ataque Wi-Fi

Tipo de ataque identificado:

El ataque más probable es un Evil Twin, es decir, un punto de acceso falso que imita a la red original del centro.

Tres evidencias que lo demuestran:

La red IES_iMES_FREE tenía más potencia de señal que la original, algo típico cuando el atacante está más cerca o utiliza un equipo más potente.

No pedía contraseña, lo que facilita que el alumnado se conecte sin sospechar.

Algunos alumnos vieron una página intermedia antes de entrar en Instagram, lo que indica un posible portal falso para capturar credenciales.

Por qué descarto otras opciones:

No parece un ataque directo al router original por fuerza bruta, porque la red falsa era abierta.

No es solo una mala configuración, ya que hay una clara suplantación del nombre de la red.

Tampoco es simplemente que alguien conociera la contraseña, porque aquí directamente no se pedía clave.

Impacto real en el instituto:

Robo de contraseñas de redes sociales.

Posible acceso a cuentas de correo si reutilizan la misma contraseña.

Suplantación de identidad.

Daño a la imagen del centro.

Intentos posteriores de acceso a sistemas internos.

2. Análisis del incidente del PDF

Qué ha ocurrido técnicamente:

Se envió un PDF supuestamente firmado, pero el visor indicaba que la firma no era válida. Además, el correo procedía de una dirección casi idéntica a la oficial (con una letra cambiada).

Esto encaja con un ataque de phishing por suplantación de identidad (dominio muy parecido al real).

Puede haber ocurrido que:

El documento fue modificado después de firmarse.

La firma no pertenecía a un certificado válido.

El correo no procedía realmente del dominio oficial.

Fallo principal:

Falta de verificación del remitente y posiblemente mala configuración o ausencia de SPF, DKIM y DMARC en el servidor de correo.

Qué revisaría en el servidor de correo:

Registro SPF.

Configuración DKIM.

Política DMARC.

Logs del servidor de correo.

Dominio exacto del remitente para comprobar si es un dominio falso.

3. Riesgo del WPS y contraseña repetida

Qué permite hacer el WPS con PIN:

El WPS con PIN permite conectarse a la red Wi-Fi usando un código numérico de 8 dígitos.

El problema es que es vulnerable a ataques de fuerza bruta, ya que el PIN se valida en dos partes, lo que reduce mucho el número real de combinaciones.

Un atacante podría obtener la contraseña real de la red sin conocerla previamente.

Por qué repetir contraseña en varias redes aumenta el riesgo:

Si se compromete una red, se comprometen todas.

Permite que alguien pase de la red de invitados a la red interna.

Facilita el movimiento lateral dentro de la infraestructura.

Qué podría pasar si alguien accede a la red interna:

Acceso a servidores del centro.

Robo de datos personales del alumnado.

Instalación de malware o ransomware.

Modificación de información académica o administrativa.

PARTE 6

Si yo fuese el responsable de IT, en las primeras 24 horas haría lo siguiente:

Desactivar WPS en todos los routers y puntos de acceso.

→ Reduce el riesgo de ataques por fuerza bruta.

Cambiar todas las contraseñas Wi-Fi por claves largas, únicas y aleatorias.

→ Reduce el riesgo de accesos no autorizados.

Eliminar cualquier red abierta y activar WPA3 o WPA2-Enterprise.

→ Evita conexiones sin cifrado.

Configurar VLAN para separar red interna y red de invitados.

→ Reduce el riesgo de acceso lateral a servidores internos.

Configurar correctamente SPF, DKIM y DMARC en el dominio del centro.

→ Reduce el riesgo de suplantación por correo electrónico.

PARTE 7 – Rediseño de la infraestructura

Protocolo de cifrado:

Implementaría WPA3-Enterprise (o WPA2-Enterprise si hay equipos antiguos).

Porque ofrece cifrado fuerte y autenticación individual mediante servidor RADIUS.

Qué haría con WPS:

Desactivarlo permanentemente, ya que es un mecanismo inseguro.

Separación de redes:

VLAN para profesorado.

VLAN para alumnado.

VLAN para invitados (solo acceso a Internet).

VLAN para administración y servidores.

Así se evita el movimiento lateral y se mejora la seguridad.

Tipo de autenticación:

Servidor RADIUS con credenciales individuales.

MFA obligatorio en correo e intranet.

Esto permite trazabilidad y mayor control de accesos.

Revisiones periódicas:

Revisión de logs de conexión Wi-Fi.

Control de dispositivos conectados.

Auditorías internas de seguridad.

Revisión de certificados digitales y caducidades.

PARTE 8

Amenaza más probable:

Un ataque Evil Twin.

Vulnerabilidad más grave:

WPS activado y falta de segmentación de red.

Medida más importante para que no vuelva a ocurrir:

Implementar WPA3-Enterprise con segmentación mediante VLAN y desactivar WPS.

Concepto que más me ha costado entender:

La firma digital, porque combina criptografía asimétrica, certificados digitales y validación de confianza. Hasta que no entiendes cómo encajan todas las piezas, resulta bastante complejo.